

Why Keyi-Sudo

简单提权小工具的设计分享

安国立



关于我

安国立 qaqland

活跃于 deepin 和 Alpine Linux 社区

关注 Wayland、GitWeb

(不懂 QT、不懂 treeland)

Keyi-Sudo

- 希望提供轻量级 Sudo 替代品、保持简单并满足日用
- 分享下个人小项目的推进思路，愉快玩耍！
- <https://hash.qaq.land/2026-keyi-sudo>
- <https://github.com/qaqland/overthinkin/tree/main/keyi-sudo>

问题与目标

- 方向 & 竞品 “勇哥我想开家奶茶店”
- 受众 & 需求 “360 度转一圈，慢点转”
- 收益 & 维护 “你这每天净亏 500”

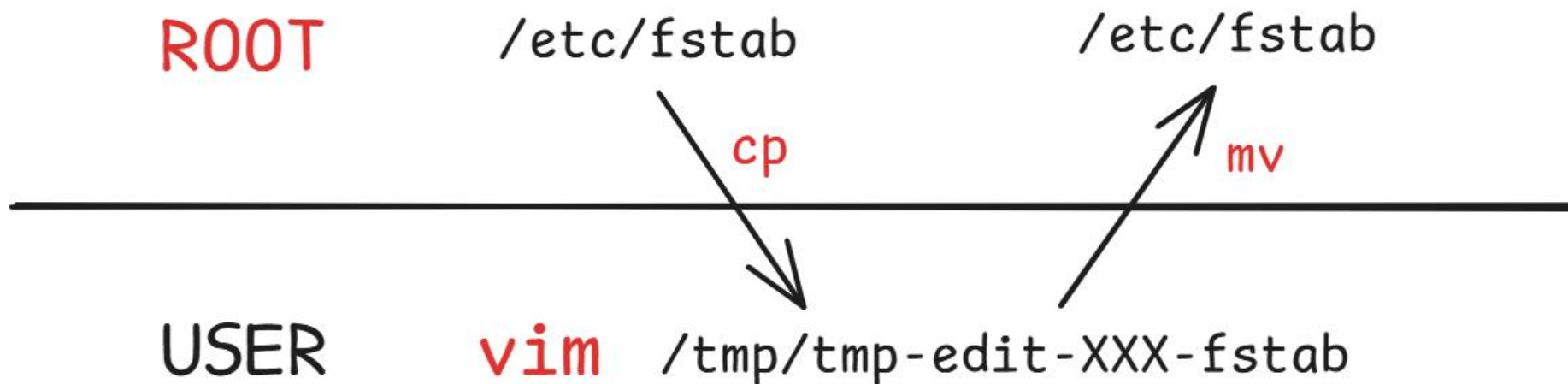
AI 横行的时代，明确问题和**限制**预期，可能比项目完成度更重要

Keyi 比 Sudo 简单

- Sudo 源码超过 500 个文件、安装体积不低于 1 MB
- 很多功能明显超出个人场景的实际需求
 - 企业级 I/O 审计与会话回放
 - LDAP/SSSD 等目录服务集成
 - 多插件链路扩展（主程序搭配一串插件）

Keyi 比 OpenDoas 好用

- OpenDoas 是 OpenBSD 组件在 Linux 系统的移植
- 少了 sudoedit 这样的借权编辑功能

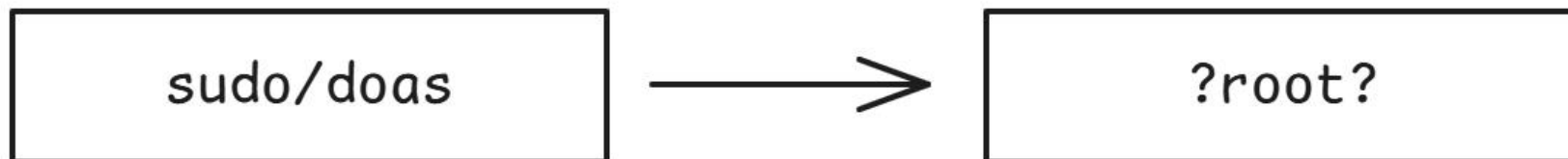


不要无效密码验证

DANGER!



It's SAFE~



作为 Linux 爱好者...

- 不服就干、学习的好机会
- 认识世界是为了改造世界
- *践行黑客精神*

如何使用

```
$ keyi id -u  
0
```

```
$ keyi F00=BAR printenv F00  
BAR
```

提权

```
$ keyi -e /etc/apt/sources.list
```

借权编辑

```
$ keyi -i
```

提权并进入到对应的交互终端

如何提权

- ruid: 启动进程的真实用户身份 (Real User ID)
- euid: 内核做权限判断时的实际参考身份 (Effective User ID)
- Linux 中, 每个进程都有上述两组身份, 大部分情况两者相等
- SUID 位可以让 euid 在启动时变成文件属主, 从而有提权能力

```
$ ls -l /usr/bin/sudo
-rwsr-xr-x 3 root root 306456 12月28日 16:19 /usr/bin/sudo
  ^ SUID 位
```

```
#define _POSIX_C_SOURCE 200809L
```

```
#include <stdio.h>
```

```
#include <stdlib.h>
```

```
#include <sys/types.h>
```

```
#include <unistd.h>
```

```
int main(void) {
```

```
    uid_t ruid = getuid();
```

```
    uid_t euid = geteuid();
```

```
    printf("before: ruid=%4d, euid=%4d\n", ruid, euid);
```

```
    // 常见于 SUID 程序: ruid=user, euid=root
```

```
    if (ruid != euid) {
```

```
        if (setuid(euid) != 0) {
```

```
            perror("setuid");
```

```
            return 1;
```

```
        }
```

```
        printf(" after: ruid=%4d, euid=%4d\n", getuid(), geteuid());
```

```
    }
```

```
    execlp("id", "id", "-u", NULL);
```

```
}
```

qaq^xiaoxin ~/test

\$./eid

before: ruid=1000, euid=1000

1000

qaq^xiaoxin ~/test

\$ ls -l

total 24

-rwxr-xr-x	1	root	root	18536	Mar	28	12:01	eid
-rw-r--r--	1	qaq	qaq	530	Mar	28	12:00	eid.c

qaq^xiaoxin ~/test

\$./eid

before: ruid=1000, euid= 0

after: ruid= 0, euid= 0

0

qaq^xiaoxin ~/test

\$ ls -l

total 24

-rwsr-xr-x	1	root	root	18536	Mar	28	12:01	eid
-rw-r--r--	1	qaq	qaq	530	Mar	28	12:00	eid.c

如何鉴权

- Keyi 基于 0 配置原则，复用文件文件权限判断
 - 调用用户必须属于指定的信任组
 - 对 group 保留 x 权限
 - 对 other 不给 x 权限（无法运行）

```
$ ls -l /usr/local/bin/keyi
-rwsr-x--- 1 root anguoli 22856  3月11日 10:45 /usr/local/bin/keyi
      ^ 其他用户没有执行权限
```

提权流程

- 解析参数和 NAME=VALUE: getopt、strchr
- 获取当前进程信息: getresuid、getpwuid
- 安全前置检查: readlink("/proc/self/exe")、stat
- 重建环境变量: getenv、setenv、clearenv
- 切换用户身份: initgroups、setuid、setgid
- 日志审计: syslog、getcwd
- 执行命令: execvp

借权编辑（简化版）

- 目标文件必须已经存在，不做“新建文件”等语义
 - ENOENT 文件不存在、EISDIR 目标路径是个目录、EACCES 或其他打开失败
 - 为这些失败场景扩展交互逻辑会明显抬高复杂度
- 仅支持单文件编辑，不支持一次编辑多个文件
 - 多文件编辑很难有真正的“原子提交”语义
 - 将状态维护责任交给用户

明确行为预期、收敛代码逻辑、降低维护成本（可能丢了部分用户）

代码之外

- README.md、CONTRIBUTING.md、man 手册页
- shell-completion 终端补全
- 构建流程、单元测试、集成测试、流水线
- 规范项目质量、准备发行版打包（可以不打但必须能打）
- 向大家介绍（就像此刻这样）

谢谢！希望玩的开心